

SIG WEB SITE

Contrôle des correctifs : les trois points critiques restants sont corrigés et vérifiés, six points majeurs sont faits, quatre reportés au déploiement, et une seule action demeure ouverte avant la mise en ligne.

GeoLight Service — SIG.tg SARL

Vitrine publique de la plateforme SIG.tg · sig-web-site (Django 5.2)

PÉRIMÈTRE RÉVISÉ : C3-C5 + M1-M10

HORS PÉRIMÈTRE : C1, C2 (CDC RÉVISÉ) · M1-M11

17 SEPTEMBRE 2026

Synthèse

Ce rapport fait suite à l'audit technique du 16 septembre 2026 et contrôle objectivement les correctifs apportés par l'équipe au projet **SIG Web Site** (vitrine Django 5.2 de la plateforme SIG.tg). Conformément aux décisions produites actées depuis, le périmètre de suivi est révisé : les deux écarts critiques liés aux formulaires d'inscription et de contact (C1, C2) sortent du référentiel, le cahier des charges ayant été modifié en ce sens, et les onze actions mineures (m1 à m11) sont exclues du comptage. Le périmètre suivi se réduit ainsi à trois points critiques (C3 à C5) et dix points majeurs (M1 à M10), soit treize points.

Le bilan est clairement favorable. Sur ces treize points, **six sont corrigés et vérifiés** dans le code (C3, C4, C5, M5, M6, M7), **deux sont partiels** (M1, M9), **quatre reportés au déploiement** (M3, M4, M8, M10), ce qui est cohérent avec leur nature opérationnelle, et **un seul reste ouvert** (M2 — mentions légales, une ligne à décommenter). Aucune régression n'a été détectée : la suite de tests passe à 253 réussis sur 253 (contre 221 lors du premier audit) et la vérification de configuration « check --deploy » ne relève plus qu'un seul avertissement, volontairement différé, contre six précédemment.

6 / 13 points corrigés et vérifiés	253/253 tests réussis (+32)	1 alerte check --deploy (contre 6)	85 % couverture du plan (partiels à 0,5)
--	---------------------------------------	--	--

Chiffres clés du suivi — vérifications du 17 septembre 2026 sur l'archive « sig-web-site-audit.zip »

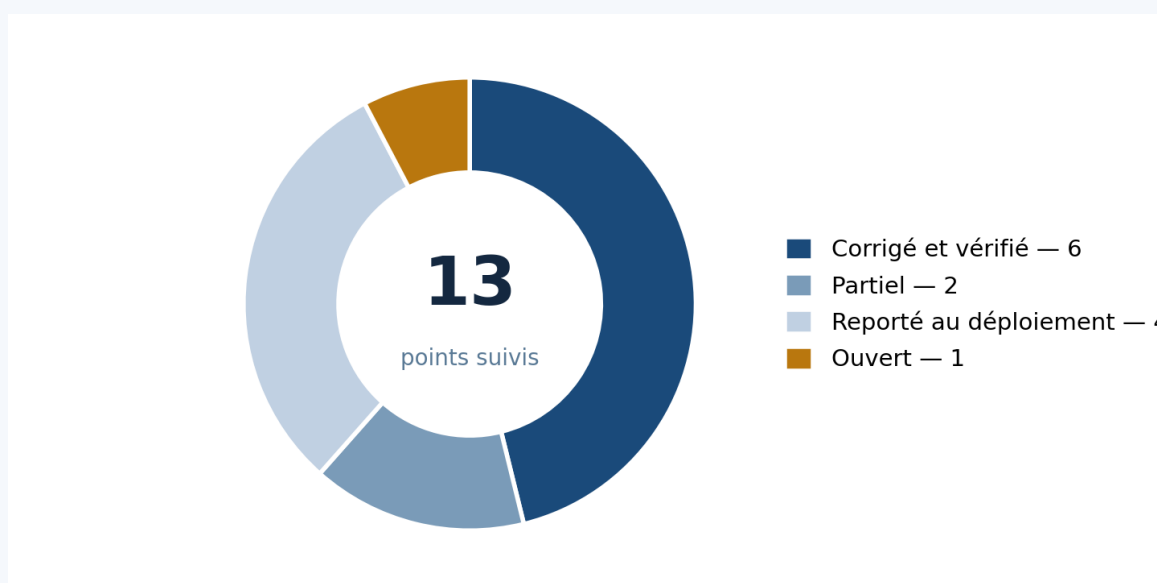


Figure 1 — Répartition des treize points du périmètre révisé par statut de traitement

Le verdict est **favorable pour entrer en phase de déploiement**, sous deux réserves de faible ampleur : fermer M2 (réactiver la route des mentions légales, obligation légale de l'éditeur qui ne se reporte pas en production) et arbitrer les compléments partiels M1 (accès à la plateforme) et M9 (documentation d'exploitation). Les quatre points reportés — e-mails transactionnels, PostgreSQL, chaîne de déploiement et verrouillage des dépendances — devront simplement être activés au moment de la mise en production, comme convenu.

1. Périmètre révisé et méthode de vérification

1.1 Ce qui est compté et ce qui est sorti du périmètre

Trois décisions du client encadrent ce second passage. Premièrement, **C1 et C2 sont retirés du référentiel** : le cahier des charges a été modifié et les exigences correspondantes (formulaire de contact complet, finalité « inscription en ligne ») ont été supprimées ; ces deux points ne sont donc plus comptés, quels que soient les constats matériels. Deuxièmement, les **onze actions mineures (m1 à m11) sont ignorées** par décision assumée : elles n'entrent ni dans le décompte ni dans le score. Troisièmement, les points majeurs non traités à ce stade sont réputés **reportés au déploiement** : M3 (e-mails transactionnels), M4 (PostgreSQL), M8 (chaîne de déploiement) et M10 (verrouillage des dépendances) sont en effet des opérations de mise en production par nature, et l'équipe n'y est pas encore.

Restent donc treize points suivis : C3 (durcissement de la configuration de production), C4 (consentement cookies et Google Analytics), C5 (conformité RGPD de la recherche) et M1 à M10. Pour chaque point, le présent rapport indique un statut unique — corrigé, partiel, reporté ou ouvert — assorti d'une preuve matérielle dans le code ou d'un résultat de commande vérifiable.

1.2 Méthode

La vérification combine quatre techniques reproductibles sur l'archive livrée « sig-web-site-audit.zip » (17 septembre 2026). En premier lieu, une revue ciblée du code modifié : réglages de production, gabarits et vues du consentement, modèle et commandes de la recherche, fixtures de contenu, routes et dépendances. En deuxième lieu, l'exécution complète de la suite de tests du projet dans un environnement virtuel propre reconstitué depuis requirements.txt (253 tests). En troisième lieu, l'audit de configuration natif de Django « manage.py check --deploy » sous les réglages de production, qui objective la couverture des réglages de sécurité. En dernier lieu, des contrôles ponctuels : vérification des migrations, installabilité des dépendances et comportement des variables d'environnement. Aucun test d'intrusion n'a été réalisé ; l'avis porte sur le code et la configuration, pas sur l'infrastructure réelle.

2. Points critiques restants (C3 à C5) : corrigés et vérifiés

2.1 C3 — Durcissement de la configuration de production : CORRIGÉ

Le fichier core/settings/prod.py contient désormais l'ensemble des réglages attendus : **DEBUG à False**, liste ALLOWED_HOSTS lue depuis l'environnement, redirection HTTPS avec en-tête de proxy, HSTS (3600 s puis montée progressive, sous-domaines inclus), cookies de session et CSRF sécurisés (Secure, HttpOnly, SameSite), en-têtes nosniff, X-Frame-Options « DENY » et Referrer-Policy, journalisation structurée, intégration Sentry conditionnelle — avec send_default_pii à False, choix favorable au RGPD — et backend e-mail SMTP paramétrable. La clé secrète n'est plus écrite en dur : elle est lue depuis la variable DJANGO_SECRET_KEY, et Rosetta a été retiré des applications installées de production (il n'est activé qu'en développement).

La vérification objective confirme ce diagnostic : lancée avec les réglages de production et une clé forte, la commande « check --deploy » ne remonte plus qu'un seul avertissement, **security.W021 (HSTS preload à False)**, explicitement commenté dans le code comme un report volontaire jusqu'à la préparation du domaine. Contre six alertes au premier audit, dont plusieurs critiques, l'écart de sécurité est résorbé. Une réserve d'hygiène subsiste, détaillée au chapitre 5 : la route de l'éditeur de traductions Rosetta reste incluse sans condition dans core/urls.py et gagnerait à être limitée au mode débogage.

2.2 C4 — Bannière de consentement et Google Analytics : CORRIGÉ

Le mécanisme exigé est en place et complet. Une bannière affichée dès la première visite propose les trois choix attendus — accepter tout, refuser tout, paramétrer — avec une gestion accessible (rôles ARIA, libellés liés). Le choix de l'utilisateur est persisté douze mois dans un cookie dédié et **journalisé en base** (modèle CookieConsent, avec action, horodatage et versions des préférences), ce qui couvre l'exigence de traçabilité du consentement. Google Analytics n'est chargé que si la catégorie « analytics » a été acceptée, avec anonymisation de l'adresse IP activée : aucun script tiers de mesure n'est exécuté avant consentement, conformément à la doctrine CNIL. L'utilisateur peut revenir sur sa décision à tout moment via une page de préférences dédiée, reliée depuis le pied de page, et une politique de cookies éditable (cookies essentiels et non essentiels gérés depuis l'admin) complète le dispositif.

2.3 C5 — Conformité RGPD de la recherche : CORRIGÉ

Le traitement de l'historique de recherche a été refondu dans le sens recommandé par l'audit. L'ancien champ d'adresse IP en clair est déprécié et n'est plus jamais écrit (valeur None systématique) ; il est remplacé par une **empreinte pseudo-anonymisée ip_hash** — SHA-256 tronqué à seize caractères, calculée avec une clé tournant mensuellement —, de sorte que l'adresse exacte d'un visiteur n'est plus reconstituée au-delà du mois courant. Une commande de gestion « purge_search_history » fournit la purge à trente jours exigée ; elle devra simplement être programmée (cron ou tâche planifiée) lors du déploiement. Enfin, la politique de confidentialité a été mise à jour : durées de conservation annoncées et description d'une mesure d'audience anonymisée sans identification individuelle. Le dispositif est conforme à la logique de minimisation et de pseudo-anonymisation de l'article 32 du RGPD.

2.4 C1 et C2 — hors périmètre, constat factuel sans comptage

Bien que sorties du référentiel révisé, deux observations factuelles méritent d'être consignées pour la suite, sans valeur d'écart. D'une part, l'application d'inscription **fonctionne désormais réellement** : la vue leads.signup_view enregistre le lead en base (nom, e-mail, organisation) puis redirige vers l'URL d'inscription de la plateforme. D'autre part, la page Contact reste une page d'information (coordonnées éditées depuis l'admin, carte et réseaux sociaux), sans formulaire — ce qui est cohérent avec le cahier des charges révisé. Deux résidus techniques liés à ces évolutions sont listés au chapitre 5 (protection anti-spam de la route d'inscription et données personnelles transmises dans la chaîne de requête de redirection) et pourront être arbitrés le moment venu.

3. Points majeurs (M1 à M10) : tableau de statut

Le tableau ci-dessous récapitule le statut de chacun des dix points majeurs, avec la preuve matérielle correspondante. Trois sont faits et vérifiés, deux partiels, quatre reportés au déploiement par décision assumée et un seul ouvert.

Tableau 1 — Statut des dix points majeurs

N°	Action (rappel)	Statut	Preuve / commentaire
M1	Page Connexion (redirection vers PLATFORM_LOGIN_URL, bouton dans le header)	Partiel	Pas de page /login/ dédiée ni bouton « Se connecter » ; l'accès passe par le CTA d'inscription du header et le lien plateforme de la page Démo
M2	Réactiver la page Mentions légales (route legal/, lien footer)	Ouvert	La route est toujours commentée dans pages/urls.py (ligne 10) ; la vue et le gabarit existent — correction de cinq minutes
M3	E-mails transactionnels réels (SMTP/SendGrid, notifications)	Reporté	Aucun envoi réel dans le code ; réglages SMTP prêts dans prod.py — activation à la mise en production
M4	PostgreSQL en production (DATABASE_URL, vérifier plein texte)	Reporté	dj-database-url et psycopg2-binary en place ; SQLite conservé en dev, PostgreSQL à activer via l'environnement
M5	Fixtures de démonstration et contenu éditorial	Fait	19 fixtures (accueil, tarifs, footer, politiques...), 5 articles de blog avec catégories, chiffres clés, partenaires et médias fournis
M6	Ajouter le Pass Solidarité (4e offre)	Fait	Fixture pricing_solidarity.json (badge « Solidarité ») à côté des 3 offres — 4 offres affichées
M7	Anti-spam (honeypot + django-ratelimit)	Fait	honeypot + limite 5 POST/min/IP sur la newsletter, 60/m et 120/m GET sur la recherche ; réserve : la route POST /signup/ n'est pas encore limitée
M8	Chaîne de déploiement (VPS, Nginx/Gunicorn, CI/CD)	Reporté	Aucun Dockerfile ni workflow dans le livrable — cohérent avec la décision (phase déploiement)
M9	Documentation (guide admin, déploiement, sauvegarde/restauration)	Partiel	README détaillé (installation, configuration, déploiement Contabo) ; il manque un guide administrateur et la procédure de sauvegarde/restauration
M10	Verrouiller les dépendances (dédoublonner, lock, pip-audit)	Reporté	requirements.txt contient encore un bloc dupliqué (21 doublons) ; fichier de lock et pip-audit à produire au déploiement

Statut par point, avec preuve sourcée dans l'archive (fichiers, fixtures, résultats de commandes)

Deux précisions éclairent les statuts partiels. Sur **M1**, le flux réel de l'utilisateur est déjà couvert : le bouton principal du header mène au formulaire d'inscription fonctionnel et la page Démo expose un lien vers la connexion de la plateforme via PLATFORM_LOGIN_URL ; il reste à trancher si un bouton « Se connecter » distinct doit apparaître dans le header, auquel cas une dizaine de lignes suffisent. Sur **M9**, la base documentaire est honorable mais orientée développeur ; la procédure de sauvegarde/restauration (pg_dump, test de restauration) et le guide administrateur restent à rédiger avant l'exploitation, sans bloquer la phase de développement.

4. Vérifications objectives : avant et après

Toutes les mesures ci-dessous ont été reproductibles sur l'archive livrée, dans un environnement virtuel propre (Django 5.2, dépendances installées depuis requirements.txt). Elles objectivent la progression entre le premier audit et celui-ci.

Tableau 2 — Comparaison des vérifications objectives

Vérification	Audit du 16/09	Suivi du 17/09
Suite de tests automatisés	221/221 réussis	253/253 réussis (+32)
check --deploy (réglages prod)	6 avertissements (W004, W008, W009, W012, W016, W020)	1 avertissement (W021, report volontaire du preload HSTS)
Migrations	À jour	À jour (makemigrations --check : rien à faire)
Installabilité des dépendances	OK	OK (avec doublons dans requirements.txt — voir M10)
Bannière cookies / GA	Absents	Présents, consentement journalisé, GA sous consentement
Stockage des IP (recherche)	IP en clair conservée	Empreinte hachée à clé tournante + purge 30 jours

Mesures reproductibles : tests, audit de configuration Django et contrôles de code

Note technique utile au déploiement : la bibliothèque django-envron donne priorité aux variables d'environnement du système sur le fichier .env. Lors de nos premières exécutions, une variable DATABASE_URL préexistante au niveau du système écrasait silencieusement celle du .env et provoquait une erreur de schéma de base de données ; le phénomène a été contourné en exportant explicitement la variable. Sur le VPS, l'équipe devra donc vérifier l'environnement réel du processus Gunicorn (service systemd, shell d'exécution) avant d'incriminer la configuration du projet.

5. Points de vigilance résiduels (hors comptage)

Les points suivants sont hors du périmètre compté — certains relèvent des décisions de périmètre, d'autres des reportés — mais chacun est actionnable rapidement et mérite une place explicite dans la file d'attente avant ou pendant la mise en production.

- **Rosetta exposé en production** : la route rosetta/ est incluse sans condition dans core/urls.py alors que l'application n'est active qu'en développement ; conditionner l'inclusion à settings.DEBUG supprime l'exposition inutile (une ligne).
- **Route d'inscription sans limitation** : POST /signup/ écrit en base sans honeypot ni rate-limit, alors que newsletter et recherche en disposent (même classe de risque que M7) ; deux décorateurs à ajouter.
- **Données personnelles dans l'URL de redirection** : l'inscription transmet nom, e-mail et organisation en paramètres de requête vers la plateforme, donc potentiellement dans les logs serveur ; à arbitrer (passage en POST côté plateforme ou troncature des paramètres).

- **Doublons de requirements.txt** : un bloc de 21 dépendances est dupliqué dans le fichier ; à dédoublonner puis verrouiller au déploiement (objet de M10).
- **Purge RGPD à planifier** : la commande `purge_search_history` existe mais doit être programmée (cron quotidien) sur l'environnement de production pour que la purge à trente jours soit effective.

6. Conclusion et prochaines étapes

Le suivi confirme un travail de correction **sérieux et vérifiable** : les trois points critiques restants sont corrigés conformément aux recommandations de l'audit initial, avec des mécanismes complets plutôt que des réponses de surface (journalisation du consentement, clé de hachage tournante, réglages commentés), et la couverture de tests s'est accrue de trente-deux cas sans régression. La réduction du périmètre opérée par le client — C1, C2 sortis du référentiel révisé, mineures ignorées — est appliquée telle quelle dans ce rapport : le score de couverture du plan ressort à 85 %, et aucun des six points corrigés ne présente de réserve bloquante.

Avant d'entrer en déploiement, la liste de contrôle suivante clôture le périmètre pré-production :

- **Fermer M2** — décommenter la route `legal/` dans `pages/urls.py` et ajouter le lien dans le footer (obligation légale éditoriale, cinq minutes) ;
- **trancher M1** — soit assumer l'accès alternatif à la plateforme (CTA d'inscription + page Démo), soit ajouter le bouton « Se connecter » dans le header ;
- étendre honeypot et rate-limit à `POST /signup/` (deux décorateurs) ;
- conditionner l'inclusion de rosetta à `settings.DEBUG` ;
- programmer le cron de `purge_search_history` (purge à 30 jours) ;
- dédoublonner `requirements.txt` puis générer le fichier de verrouillage (ouverture de M10).

Au déclenchement de la mise en production, les quatre points reportés s'activent dans l'ordre logique de la chaîne : M4 (PostgreSQL et vérification de la recherche plein texte), M3 (e-mails transactionnels sur SMTP), M8 (provisioning du VPS, Nginx/Gunicorn, CI/CD) et M10 (dépendances verrouillées et pip-audit), en complétant M9 par les guides d'exploitation. Une fois ces activations réalisées et la liste de contrôle ci-dessus fermée, le site vitrine sera dans un état conforme au référentiel révisé et prêt pour la mise en ligne.